

Modern Cryptography

Oracle

Plan

1. 암호학에서 '오라클'이란?
2. 서명 오라클 (Signing Oracle)
3. 무작위 오라클 (Random Oracle)
4. 안전성 환원과 수학적 손실
5. ROM의 한계와 확장

암호학에서 '오라클'이란?

정의

핵심 개념 (Black-Box):

- 입력을 주면 사전에 정의된 규칙에 따라 즉각 올바른 출력을 반환하는 가상의 블랙박스
- 사용자는 비밀키(sk)나 내부 연산 구조를 알 수 없고 쿼리(Query)-응답(Response)만 관찰 가능

이중성

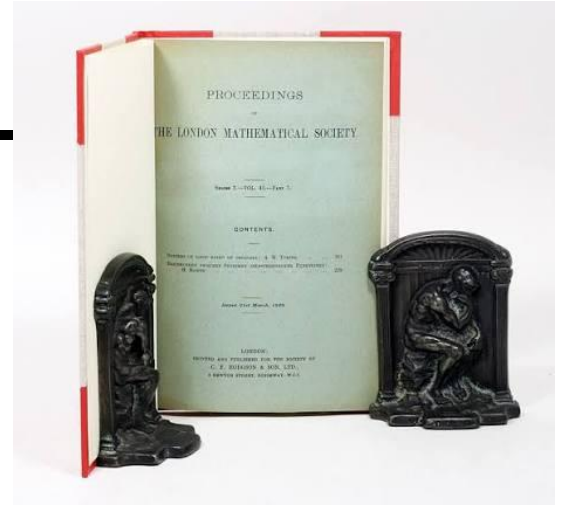
공격자 관점 (Adversary View):

- 공격자의 극대화된 능력을 수학적으로 모델링하는 도구

방어자/증명자 관점(Simulator View):

- 복잡한 실제 시스템을 이상적 수학적 대상으로 환원해 엄밀한 증명을 돕는 도구

오라클 개념의 기원



기원:

- 앨런 튜링이 1939년 박사학위 논문("Systems of Logic Based on Ordinals")에서 처음 제안한 개념
- 일반적인 튜링 기계에 "판정 불가능한(undecidable) 문제조차 단 한 스텝에 답해주는 블랙박스"를 추가로 장착한 계산 모델을 Oracle Turing Machine이라 부름

오라클 개념의 기원

Let us suppose that **we are supplied with some unspecified means** of solving number theoretic problems; **a kind of oracle as it were**. We will not go any further into the nature of this oracle than to say that **it cannot be a machine....** (pp. 13-14)

오라클 개념의 기원

- "We are supplied with some unspecified means...":

작동 원리는 중요치 않으며, 질문에 즉시 정답을 알려주는 기능적 특징
에 집중함

- "It cannot be a machine":

알고리즘으로 해결 불가능한, 초월적 능력을 지닌 존재를 의미함

오라클을 쓰는 이유

암호학적 증명의 공통 패턴:

- 안전성 증명은 대체로 실제 실행 환경과 이상화된 환경을 공격자가 구별할 수 없게 만드는 방식으로 이루어짐

오라클을 쓰는 이유

오라클의 역할:

- 이 "이상화된 환경"을 수학적으로 다루기 쉬운 형태로 구현하는 표준 인터페이스.
- 복잡한 실제 알고리즘·상호작용을 "질의를 넣으면 응답이 나오는" 단순한 함수 호출로 추상화함으로써, 증명자가 그 내부를 자유롭게 설계·조작할 수 있게 만듦

오라클을 쓰는 이유

환원(Reduction) 증명의 3요소:

- I. 공격자의 실제 능력을 오라클 접근 권한으로 캡슐화한다
- II. 증명자가 그 오라클 역할을 대신 연기한다
- III. 공격자가 성공하면, 그 성공을 이용해 다른 어려운 문제를 해결한다

암호학 전반의 오라클

오라클 유형	이상화 대상	사용처
Signing Oracle	합법적 서명자의 서명 행위	UF-CMA (전자서명)
Decryption Oracle	합법적 수신자의 복호화 행위	IND-CCA (공개키 암호)
Random Oracle	해시 함수의 이상적 무작위성	ROM (FDH, PSS, OAEP 등)
Ideal Cipher Oracle	블록암호를 완전 무작위 순열로	Ideal Cipher Model
Generic Group Oracle	군(group) 연산의 대수적 구조 은닉	Discrete Log 기반 스킴 (Schnorr 등)
Algebraic Group Model Oracle	Generic Group보다 현실적인 절충 모델	최근(2018~) DL 기반 안전성 증명

서명 오라클 (Signing Oracle)

UF-CMA

- 현실 위협:
 - 공격자가 도청으로 $(M_1, \sigma_1), (M_2, \sigma_2), \dots$ 를 확보하거나, 사회공학으로 피해자에게 특정 문서 서명을 유도

UF-CMA

- UF-CMA (Unforgeability under Chosen Message Attack):
 - 공격자에게 원하는 모든 메시지에 대한 서명을 무제한 발급하는 서명 오라클을 주어줌
 - 그럼에도 한 번도 서명받지 않은 새로운 M^* 에 대한 σ^* 를 만들지 못하면 안전

**서명 오라클은 현실보다 훨씬 강력한 능력을 공격자에게 가정해
가장 보수적인 안전 마진을 확보하는 장치**

- 그럼에도 안 번도 서명받지 않은 새로운 M^* 에 대한 σ^* 를 만들지 못하면 안전

UF-CMA 게임

- **목적:** 서명 보안성 증명을 위한 공격자-방어자 간의 수학적 게임 모델링
- **Initialize 단계:** 방어자 측 키 쌍 생성 및 공격자에게 공개키(vk) 부여
- **Sign 단계:** 공격자가 원하는 메시지 오라클 요청 → 획득 후 시스템에 요청 목록(S) 기록
- **Finalize 단계:** 공격자가 위조 서명 제출 → 시스템이 최종 유효성 판별 및 승패 결정

Plain RSA에서의 서명 오라클 악용 공격

문제: 해시를 거치지 않은 Plain RSA 서명 $\sigma = M^d \bmod N$ 의 곱셈 준동형성

공격 (2회 질의로 위조):

- 목표: $M_{target} = y_1 \cdot y_2 \bmod N$ 에 대한 위조 서명
- 오라클에 y_1, y_2 질의 $\rightarrow x_1 = y_1^d \bmod N, ; x_2 = y_2^d \bmod N$ 획득
- $x_{target} = x_1 \cdot x_2 \bmod N = (y_1 y_2)^d \bmod N$

Plain RSA에서의 서명 오라클 악용 공격

$S = y_1, y_2$ 에 없는 M_{target} 에 대한 유효 서명 생성 → UF-CMA 붕괴
→ 메시지를 해시에 먼저 통과시켜야 하는 이유

- 오라클에 y_1, y_2 질의 → $x_1 = y_1^d \bmod N, ; x_2 = y_2^d \bmod N$ 획득
- $x_{target} = x_1 \cdot x_2 \bmod N = (y_1 y_2)^d \bmod N$

무작위 오라클 (Random Oracle)

무작위 오라클

- 도입 배경:

SHA-256 등 실제 해시 함수의 복잡한 비트 연산을 그대로 증명에 포함하는 것은 현실적으로 불가능

- 동작 원리:

- I. 새로운 입력 $M \rightarrow$ 균등 무작위 y 를 뽑아 반환, 매핑 테이블 (M, y) 기록
- II. 과거 입력 M 재질의 $\rightarrow$ 테이블에서 동일 y 반환

실제 해시함수와 차이점

- **실제 해시 함수:**

공개된 결정론적 알고리즘, 난수 생성기가 아니며 내부 구조 고정

- **무작위 오라클:**

증명을 위해 잠시 도입하는 수학적 가상 도구, 완전한 균등·독립 분포를 보장받는 세계관

실제 해시함수와 차이점

실제 해시 함수.

ROM은 실제 시스템의 물리적 성질이 아니라,
증명을 가능하게 하기 위해 잠시 빌려오는 강력한 가정이다

증명을 위해 잠시 빌려오는 강력한 가정이다, 단기간 동안 검증 가능

보장받는 세계관

FDH에서의 해결책

- **PKCS#1의 한계:**

고정 패딩 구조 때문에 해시 결과가 $\mathbb{Z}_N^*$ 전체를 채우지 못함(Full Domain이 아님) → RSA 트랩도어 문제와의 환원 연결고리가 약해짐

- **FDH의 접근법:**

해시 함수가 M 을 $\mathbb{Z}_N^*$ 전체에 고르게 매핑(Full Domain) → ROM에서 균등 분포 보장 → RSA 일방향성(One-wayness) 증명으로 엄밀히 환원 가능

Full Domain Hash (FDH)

알고리즘	연산
$\mathcal{K}$	$(N, p, q, e, d) \stackrel{?}{\leftarrow} \mathcal{K}_{rsa}, vk = (N, e), sk = (N, d)$
$\mathcal{S}_{(N,d)}(M)$	$y \leftarrow H(M); x \leftarrow y^d \pmod{N}; \text{return } x$
$\mathcal{V}_{(N,e)}(M, x)$	$y \leftarrow H(M); \text{return } (x^e \pmod{N} \stackrel{?}{=} y)$

안전성 환원과 수학적 손실

안전성 환원

- **대전제:**

FDH를 위조하는 공격자 A 가 존재한다면, 이를 이용해 RSA 일방향성(역원 찾기)을 푸는 알고리즘 B 를 만들 수 있다. RSA 문제는 어렵다고 알려져 있으므로, 그런 A 는 존재할 수 없다.

- **B 의 과제:**

A 가 의심하지 않도록 무작위 오라클(해시 질의 H)과 서명 오라클(서명 질의 S)을 모두 완벽히 대행해야 함

오라클 프로그래밍

- **핵심:** 무작위 오라클은 B 가 응답값을 원하는 대로 채워 넣을 수 있는 블랙박스
- B 는 자신이 풀어야 할 RSA 문제값 $y(x = y^d \bmod N$ 을 구해야 함)를 A 의 해시 질의 응답 중 하나에 몰래 삽입

오라클 프로그래밍

시나리오:

- A 가 $H(M)$ 을 질의할 때, B 는 무작위 r 을 뽑아 $H(M) = y \cdot r^e \bmod N$ 로 프로그래밍 후 반환
- A 가 이 M 에 대해 위조 서명 σ' 를 제출하면, B 는 $\sigma' = x \cdot r \bmod N$ 관계를 이용해 $x = \sigma^* \cdot r^{-1} \bmod N$ 을 추출

수학적 손실

$$Adv_{RSA}^{ow}(B) \geq \frac{1}{q_H} \cdot Adv_{FDH}^{uf-cma}(A)$$

- **메커니즘:** A 는 최대 q_H 번(예: $2^{60} \sim 2^{80}$) 질의 $\rightarrow B$ 는 A 가 최종 위조에 실패할 때 M^* 이 어느 질의인지 미리 찍어야 함 $\rightarrow$ 적중 확률 $1/q_H$
- **단점:** 느슨한 환원 $\rightarrow$ 동일 보안 강도를 유지하려면 훨씬 긴 RSA 키 필요
 $\rightarrow$ 연산 속도 저하

수학적 손실

$$Adv_{FDH}^{uf-cma}(A); \leq; q_H \cdot Adv_{RSA}^{ow}(B)$$

- **메커니즘:** A 는 최대 q_H 번(예: $2^{60} \sim 2^{80}$) 질의 $\rightarrow B$ 는 A 가 최종 위조에 실패할 때 M^* 이 어느 질의인지 미리 찍어야 함 $\rightarrow$ 적중 확률 $1/q_H$
- **단점:** 느슨한 환원 $\rightarrow$ 동일 보안 강도를 유지하려면 훨씬 긴 RSA 키 필요 $\rightarrow$ 연산 속도 저하

RSA-PSS

- **해결:** 서명 생성 시 매번 새로운 무작위 솔트(Salt, 길이 k_0) 값을 가미

$$Adv_{PSS}^{uf-cma}(A); \leq; Adv_{RSA}^{ow}(B); +; \varepsilon(q_H, q_S, k_0)$$

- $\varepsilon(q_H, q_S, k_0)$ 는 솔트 공간 2^{k_0} 에 대한 birthday-bound 형태의 무시 가능한 덧셈 항이며, q_H 에 대해 곱셈적으로 커지지 않는다

RSA-PSS

**FDH는 손실이 q_H 에 곱셈적으로 붙지만,
PSS는 손실이 거의 무시 가능한 덧셈 항으로 줄어든다**

덧셈 항이며, q_H 에 대해 곱셈적으로 커지지 않는다

ROM의 한계와 확장

ROM 자체의 한계

- ROM 하 수학적 안전성이 100% 증명되어도, 실제 구현에서 SHA-256/SHA-3로 교체하는 순간 "완벽한 무작위 오라클처럼 안전하다"는 정량적 보장은 엄밀히 없음
- **Canetti, Goldreich, Halevi (CGH98):**
 - ROM 하에서는 절대 안전하지만, 구체적인 실제 해시 함수로 교체하는 순간 반드시 안전성이 파괴되는 인위적 프로토콜이 이론적으로 존재함을 증명

ROM 자체의 한계

- ROM 하 수학적 안전성이 100% 증명되어도, 실제 구현에서 SHA-256/SHA-3로

**ROM은 "실제 해시 함수에 구조적 결함이 없다"는
전제하의 실용적 타협점**

- ROM 하에서는 절대 안전하지만, 구체적인 실제 해시 함수로 교체하는 순간 반드시 안전성이 파괴되는 인위적 프로토콜이 이론적으로 존재함을 증명

이후의 대응

- **현실:**

CGH98의 반례는 인위적으로 설계된 스킴에서만 나타나며, FDH·PSS·OAEP 등 자연스러운 스킴이 이 방식으로 깨진 사례는 지금까지 보고된 바 없음

- **이론적 대응:**

1. Katz–Wang (2003): PSS의 무작위 솔트 대신 1비트의 무작위성만 추가해도 진정한 타이트 환원을 얻을 수 있음을 보임
2. 표준모델(Standard Model) 서명 스킴: ROM 가정 자체를 배제하고 증명하는 스킴도 존재하나 효율성이 떨어짐